SECURITY FINDINGS & REMEDIATION TRACKER

Ceraphin Energy Solutions (CES) | GRC Portfolio Artifact

Author: Alexander Dabbs

Purpose: This companion document summarizes the five selected controls in the CES mini-gap assessment and organizes illustrative risk ratings, accountable owners, remediation targets, and closure evidence. It is a focused portfolio example, not a complete compliance audit or certification assessment.



Status Distribution	
■ Compliant	**2** controls (40%)
■ Partial Compliance	**1** control (20%)
■ Non-Compliant	**2** controls (40%)
Assessment Scope: 5 selected controls	

Status Overview

ID / Control	Status	Illustrative Risk	Primary Follow-Up
CES-001 ISO 27001 A.5.15 Access Control	**Compliant**	Low	Maintain IAM separation; periodic review
CES-002 ISO 27001 A.5.17 Authentication Information	**Compliant**	Low	Maintain MFA; verify enforcement
CES-003 ISO 27001 A.8.20 Network Security	**Partial Compliance**	High	Review and strengthen network isolation
CES-004 ISO 27001 A.8.23 Web Filtering	**Non-Compliant**	High	Implement outbound web filtering
CES-005 ISO 27001 A.5.24-A.5.26 Incident Response Preparedness	**Non-Compliant**	Critical	Approve plan and test response readiness

FINDING DETAILS & REMEDIATION PLAN

Each record links the assessment observation to an accountable owner, a proposed target, and evidence that could support closure or ongoing assurance.

CES-001 | Access Control ISO 27001 A.5.15	**COMPLIANT**
Risk Rating	**Low** High-impact systems; control appears to be implemented based on evidence reviewed.
Finding	IAM configuration manifests indicate separate permissions for AI model training and production SCADA environments. Based on the evidence provided, the control appears implemented. Operational effectiveness was not independently tested as part of this assessment.
Remediation Strategy	Maintain role separation and least-privilege permissions. Continue periodic access review and investigate exceptions.
Owner	IAM / Identity Security Lead
Target Timeline	No corrective action currently assigned. Reevaluate during the next quarterly access review.
Evidence Required	IAM configuration manifests; role/permission mapping; latest access review record; evidence of approved exceptions, if any.

CES-002 | Authentication Information ISO 27001 A.5.17	**COMPLIANT**
Risk Rating	**Low** High-impact systems; authentication safeguards described as implemented.
Finding	The scenario describes hardware-backed MFA for interactive remote sessions. Okta identity rules are cited as evidence for hardware-key enforcement. The assessment does not independently validate the cryptographic module certification or test operational effectiveness.
Remediation Strategy	Maintain the MFA configuration and periodically verify enforcement, exceptions, and validity of supporting assurance documentation.
Owner	Identity Security Lead
Target Timeline	No corrective action currently assigned. Reevaluate during the next scheduled authentication control review.
Evidence Required	Exported identity-provider policy; sample authentication logs or test results; inventory of covered accounts; applicable cryptographic validation documentation.

FINDING DETAILS & REMEDIATION PLAN (CONTINUED)

CES-003 | Network Security ISO 27001 A.8.20	**PARTIAL COMPLIANCE**
Risk Rating	**High** The AI prediction API shares upstream transit-gateway architecture with the corporate development cluster.
Finding	The public API layer supporting the AI predictive consumption engine shares upstream transit-gateway architecture with the corporate development cluster. This creates a potential aggregation and boundary risk; effective isolation should be verified.
Remediation Strategy	Review routing and security boundaries, then separate the AI API path from standard corporate development routing where justified. Apply independent inspection and firewall controls; and document any required exceptions.
Owner	Cloud Network Engineering Team, with Cloud Security oversight
Target Timeline	Target within 30 days of assignment; validate feasibility and service dependencies before finalizing the date.
Evidence Required	Current and target network diagrams; transit-gateway route tables; firewall/security-group rules; segmentation test results; approved change record.

CES-003 | Web Filtering ISO 27001 A.8.23	**NON-COMPLIANT**
Risk Rating	**High** AI training containers make external connections without outbound proxy content filtering.
Finding	AI training workloads retrieve energy indices and public regulatory updates from third-party domains, but the scenario states these containers lack outbound proxy content filtering. This increases exposure to malicious destinations and unauthorized outbound communications.
Remediation Strategy	Implement outbound web filtering and restrict egress to approved destinations. Confirm required external data sources, monitor allowed and blocked traffic, and document exceptions.
Owner	Cloud Platform Engineering Team, with Security Engineering oversight
Target Timeline	Target within 30 days of assignment; prioritize sooner if risk review identifies active exposure.
Evidence Required	Proxy or egress-filter configuration; approved destination allowlist; relevant network policy; test results showing approved destinations work and unauthorized destinations are blocked; monitoring samples.

FINDING DETAILS & REMEDIATION PLAN (CONTINUED)

CES-003 | Incident Response Preparedness ISO 27001 A.5.24-A.5.26	**NON-COMPLIANT**
Risk Rating	**Critical** No approved, scenario-specific response procedures or exercise evidence was provided for incidents affecting cloud SCADA gateways and AI infrastructure.
Finding	Documented and approved incident response procedures specific to incidents affecting cloud-hosted SCADA gateways and AI energy prediction infrastructure were absent. No evidence of incident response exercises or testing was provided.
Remediation Strategy	Approve an incident response plan covering classification, escalation, roles, communications, containment, and recovery. Include scenarios for unauthorized SCADA gateway access, compromised cloud credentials, and suspicious AI workload activity. Run a tabletop exercise and track resulting actions.
Owner	Incident Response / SOC Lead, with OT Security and Cloud Operations
Target Timeline	Plan approval within 30 days; tabletop exercise within 60 days; dates are proposed planning targets.
Evidence Required	Approved incident response plan; contact/escalation matrix; tabletop scenario and attendance; exercise results and after-action report; action log showing gaps assigned and tracked.

Rating Note: Risk ratings, accountable roles, and target timelines in this tracker are proposed examples for the fictional scenarios. They should be confirmed through a documented risk methodology and stakeholder agreement in a real engagement. For compliant controls, the tracker records ongoing assurance activities rather than implying that no monitoring is needed.

Closure Principle: A finding should be closed only after the assigned owner provides the agreed evidence and the assessor reviews it against the stated closure criteria. Where remediation is not yet complete, record the current status, remaining actions, and any formally accepted risk.